

Security+ 2.2 · Impersonation

Mestre CyberSec — Guia Completo CompTIA Security+ (SY0-701) · **Aula 2.2 — Impersonation (5:52)** · [Vídeo Oficial no YouTube ↗](#) · [Página no Professor Messer ↗](#)

Resumo Executivo da Aula: Roubo de identidade na conversa: BEC (Business Email Compromise — 'falo pelo CEO'); tailgating (entrar na porta atrás da pessoa); shoulder surfing (olhar sobre o ombro); dumpster diving (papel na lixeira); brand impersonation (falso suporte).

Highlights que a prova cobra

- BEC: o email SE PASSA pelo executivo (vítima interna)
- Whaling: o email MIRA o executivo (spear de exec) — diferente de BEC
- Tailgating: entra na porta atrás de quem tem acesso

Dicas de prova & Cenários Típicos

- 'sender claims to be an executive' = BEC
- 'follows an authorized person through a door' = tailgating/piggybacking

Cenário clássico de exame: Cenário: 'atacante manda email dizendo ser o CEO e pede transferência urgente' = BEC — não whaling (whaling MIRA o CEO; BEC SE PASSA por ele).

Além do Vídeo: O que a CompTIA cobra na prova (Conceitos, Siglas e Armadilhas da Aula 2.2 — Impersonation)

Por que este aprofundamento é cobrado no exame? O vídeo do Professor Messer apresenta uma introdução ágil. Porém, a banca oficial CompTIA Security+ (SY0-701) exige raciocínio de engenharia prática e cobra diretamente os seguintes protocolos, jargões e ferramentas no contexto desta aula:

- **Princípio do Menor Privilégio:** Usuários e sistemas devem ter apenas as permissões estritamente necessárias para suas funções corporativas.
- **Defesa em Profundidade (Defense-in-Depth):** Aplicação de múltiplas camadas de controles (técnicos, administrativos, físicos) para evitar que a falha de um exponha todo o ambiente.

Armadilhas e Pegadinhas Clássicas da Banca:

- Nunca decore apenas letras ou siglas: a CompTIA altera o cenário exigindo que você justifique por que o controle escolhido é o *MAIS adequado* dentre 4 opções válidas.
- Fique atento às restrições do enunciado: 'sem custo adicional' favorece configurações nativas do SO; 'maior granularidade de rede' favorece TACACS+ em vez de RADIUS; 'não-repúdio' exige chave privada/assinatura digital.

Perguntas de treino comentadas (10 questões)

Gabarito com resolução passo a passo e análise técnica individual de cada distrator no fim. Tente responder antes de olhar.

1. Um golpista manda e-mail SE PASSANDO pelo CEO e ordena que o financeiro faça uma transferência urgente. Que ataque é esse?

- A)** BEC / CEO fraud (fraude do CEO)
- B)** Whaling
- C)** Vishing
- D)** Tailgating

2. Um funcionário recebe ligação de alguém se passando por suporte técnico solicitando senha para 'atualização do sistema'. Que técnica é essa?

- A) Vishing**
- B) Pretexting**
- C) Baiting**
- D) Tailgating**

3. Golpista liga se passando por suporte de TI e cria urgência pra tu dar a senha. O princípio de engenharia social explorado é:

- A) Escassez**
- B) Autoridade + urgência**
- C) Prova social**
- D) Reciprocidade**

4. Um atacante usa RFID para clonar crachás de funcionários e acessar áreas restritas. Que tipo de ataque físico é esse?

- A) Tailgating**
- B) Shoulder surfing**
- C) Clonagem de credenciais**
- D) Dumpster diving**

5. Cenário corporativo (Impersonation): Durante uma revisão de segurança e auditoria de conformidade com o exame CompTIA Security+ (SY0-701, Seção 2.2), um analista avalia o seguinte requisito técnico: 'BEC: o email SE PASSA pelo executivo (vítima interna)'. Qual é a melhor recomendação ou classificação de controle aplicável?

- A) Desativar temporariamente os logs de auditoria para acelerar o throughput do sistema**
- B) Substituir controles técnicos preventivos por termos de adesão informais**
- C) Permitir acesso compartilhado entre administradores com credenciais genéricas**
- D) Implementar a solução correspondente: BEC: o email SE PASSA pelo executivo (vítima interna)...**

6. Cenário corporativo (Impersonation): Durante uma revisão de segurança e auditoria de conformidade com o exame CompTIA Security+ (SY0-701, Seção 2.2), um analista avalia o seguinte requisito técnico: 'Whaling: o email MIRA o executivo (spear de exec) — diferente de BEC'. Qual é a melhor recomendação ou classificação de controle aplicável?

- A)** Desativar temporariamente os logs de auditoria para acelerar o throughput do sistema
- B)** Substituir controles técnicos preventivos por termos de adesão informais
- C)** Implementar a solução correspondente: Whaling: o email MIRA o executivo (spear de exec) — diferente de BEC...
- D)** Permitir acesso compartilhado entre administradores com credenciais genéricas

7. Cenário corporativo (Impersonation): Durante uma revisão de segurança e auditoria de conformidade com o exame CompTIA Security+ (SY0-701, Seção 2.2), um analista avalia o seguinte requisito técnico: 'Tailgating: entra na porta atrás de quem tem acesso'. Qual é a melhor recomendação ou classificação de controle aplicável?

- A)** Implementar a solução correspondente: Tailgating: entra na porta atrás de quem tem acesso...
- B)** Desativar temporariamente os logs de auditoria para acelerar o throughput do sistema
- C)** Substituir controles técnicos preventivos por termos de adesão informais
- D)** Permitir acesso compartilhado entre administradores com credenciais genéricas

8. Cenário corporativo (Impersonation): Durante uma revisão de segurança e auditoria de conformidade com o exame CompTIA Security+ (SY0-701, Seção 2.2), um analista avalia o seguinte requisito técnico: 'sender claims to be an executive' = BEC'. Qual é a melhor recomendação ou classificação de controle aplicável?

- A)** Desativar temporariamente os logs de auditoria para acelerar o throughput do sistema
- B)** Substituir controles técnicos preventivos por termos de adesão informais
- C)** Implementar a solução correspondente: 'sender claims to be an executive' = BEC...
- D)** Permitir acesso compartilhado entre administradores com credenciais genéricas

9. Cenário corporativo (Impersonation): Durante uma revisão de segurança e auditoria de conformidade com o exame CompTIA Security+ (SY0-701, Seção 2.2), um analista avalia o seguinte requisito técnico: 'follows an authorized person through a door' = tailgating/piggybacking'. Qual é a melhor recomendação ou classificação de controle aplicável?

- A)** Desativar temporariamente os logs de auditoria para acelerar o throughput do sistema
- B)** Implementar a solução correspondente: 'follows an authorized person through a door' = tailgating/piggybacking...
- C)** Substituir controles técnicos preventivos por termos de adesão informais
- D)** Permitir acesso compartilhado entre administradores com credenciais genéricas

10. Cenário corporativo (Impersonation): Durante uma revisão de segurança e auditoria de conformidade com o exame CompTIA Security+ (SY0-701, Seção 2.2), um analista avalia o seguinte requisito técnico: 'Cenário: 'atacante manda email dizendo ser o CEO e pede transferência urgente' = BEC — não whaling (whaling MIRA o CEO; BEC SE PASSA por ele)'. Qual é a melhor recomendação ou classificação de controle aplicável?

- A)** Desativar temporariamente os logs de auditoria para acelerar o throughput do sistema
- B)** Implementar a solução correspondente: Cenário: 'atacante manda email dizendo ser o CEO e pede transferência urgen...
- C)** Substituir controles técnicos preventivos por termos de adesão informais
- D)** Permitir acesso compartilhado entre administradores com credenciais genéricas

GABARITO COMENTADO COM ANÁLISE DETALHADA DOS DISTRATORES

1) A — BEC / CEO fraud (fraude do CEO).

✓ **Por que está certa:** A alternativa correta é 'BEC / CEO fraud (fraude do CEO)'. Business Email Compromise (BEC) é uma categoria de ataque de engenharia social em que o atacante se passa por um executivo de alto escalão (como o CEO) ou por um parceiro de negócios confiável para induzir funcionários a realizar transferências financeiras não autorizadas ou divulgar informações confidenciais. No caso descrito, o golpista envia um e-mail fraudulento se passando pelo CEO e ordena uma transferência urgente ao setor financeiro. Isso se enquadra perfeitamente na definição de BEC, que é reconhecida pela CompTIA como um vetor de ataque baseado em impersonação e engenharia social. A variante específica em que o CEO é personificado é chamada de CEO fraud. Portanto, a opção 'BEC / CEO fraud (fraude do CEO)' é a que melhor descreve o ataque.

✗ **Por que as outras estão erradas:**

- *Whaling*: Whaling é um tipo de ataque de phishing direcionado especificamente a executivos de alto nível (como CEOs, CFOs, etc.). O objetivo é obter informações confidenciais ou acesso a sistemas críticos por meio de e-mails fraudulentos que se passam por fontes confiáveis. No entanto, no cenário descrito, o atacante não está mirando o CEO, mas sim se passando por ele para enganar o setor financeiro. Portanto, whaling não é o termo correto, pois descreve o alvo (o executivo) e não o modus operandi de impersonação do CEO para fraudar subordinados.
- *Vishing*: Vishing é a prática de engenharia social realizada por meio de chamadas telefônicas (voice phishing), onde o atacante se passa por uma entidade confiável para obter informações sensíveis, como senhas ou dados financeiros. No enunciado, o ataque ocorre por e-mail, não por telefone. Portanto, vishing não se aplica ao canal utilizado. Além disso, o vishing não envolve necessariamente a personificação do CEO para ordenar transferências, mas sim ligações fraudulentas em geral.
- *Tailgating*: Tailgating é uma técnica de acesso físico não autorizado em que uma pessoa segue outra em uma área restrita sem se autenticar, geralmente explorando a cortesia ou distração do funcionário autorizado. Não tem relação com ataques de engenharia social por e-mail ou fraudes financeiras. O cenário descreve um ataque cibernético baseado em e-mail fraudulento, não uma invasão física. Portanto, tailgating é completamente inadequado para a situação.

2) A — Vishing.

✓ **Por que está certa:** A alternativa correta é 'Vishing'. Vishing é a combinação de 'voice' e 'phishing', ou seja, engenharia social realizada por meio de chamadas telefônicas (VoIP ou rede telefônica tradicional). No cenário descrito, o atacante se passa por suporte técnico para obter a senha da vítima, caracterizando exatamente um ataque de vishing. A CompTIA Security+ classifica vishing como um ataque de engenharia social baseado em voz, onde a interação em tempo real aumenta a pressão psicológica e a credibilidade percebida. O objetivo é induzir a vítima a revelar credenciais ou executar ações prejudiciais.

✗ **Por que as outras estão erradas:**

- *Pretexting*: Pretexting é a criação de um cenário ou pretexto falso para obter informações. Embora o atacante no enunciado use um pretexto (falso suporte técnico), o vetor principal é o telefone. Pretexting é um elemento comum em muitos ataques de engenharia social, incluindo vishing, phishing e smishing. A alternativa é incorreta porque não especifica o canal telefônico, que é a característica definidora do vishing. Em termos técnicos, pretexting é a técnica de construção da história, enquanto vishing é o meio de entrega via voz.
- *Baiting*: Baiting envolve deixar um dispositivo físico (como um pendrive infectado) ou uma isca digital para que a vítima o utilize, explorando a curiosidade. Não há relação com chamadas

telefônicas ou solicitação direta de senha por voz. A alternativa é incorreta porque descreve um ataque que depende de ação física ou interação com mídia removível, não de interação verbal em tempo real.

- *Tailgating*: Tailgating é uma técnica de acesso físico não autorizado em que o atacante segue um funcionário autorizado através de uma porta segura sem se autenticar. Não envolve telefone, engenharia social verbal ou obtenção de senha. A alternativa é incorreta porque pertence à categoria de ataques físicos, enquanto o cenário descreve um ataque remoto de engenharia social por voz.

3) B — Autoridade + urgência.

✓ **Por que está certa:** A alternativa correta é 'Autoridade + urgência'. A engenharia social explora vieses cognitivos e princípios psicológicos para manipular vítimas. No cenário, o golpista se passa por suporte de TI, o que invoca o princípio da autoridade (a vítima tende a obedecer a figuras de autoridade). Além disso, ele cria um senso de urgência para pressionar a vítima a agir rapidamente, sem pensar criticamente. A combinação de autoridade e urgência é uma tática clássica de engenharia social, reconhecida pela CompTIA. Portanto, a opção 'Autoridade + urgência' descreve com precisão os princípios explorados.

✗ **Por que as outras estão erradas:**

- *Escassez*: Escassez é um princípio de persuasão que explora a percepção de que recursos são limitados, criando uma sensação de que a oportunidade pode ser perdida se não agir imediatamente. No cenário, não há menção a recursos escassos ou ofertas limitadas. O golpista não está oferecendo algo em quantidade limitada, mas sim se passando por autoridade e criando urgência. Portanto, escassez não é o princípio aplicável.
- *Prova social*: Prova social é a tendência de as pessoas seguirem o comportamento dos outros, assumindo que ações tomadas por muitos são corretas. No ataque descrito, não há menção a outras pessoas fazendo o mesmo ou endossando a ação. O golpista não usa a ideia de que 'todos estão fazendo' para convencer a vítima. Portanto, prova social não é o princípio explorado.
- *Reciprocidade*: Reciprocidade é o princípio de que as pessoas se sentem obrigadas a retribuir um favor ou concessão. No cenário, o golpista não oferece nada primeiro para depois pedir a senha; ele simplesmente se passa por suporte e cria urgência. Não há troca de favores. Portanto, reciprocidade não se aplica.

4) C — Clonagem de credenciais.

✓ **Por que está certa:** A alternativa correta é 'Clonagem de credenciais'. A clonagem de credenciais ocorre quando um atacante copia os dados de um cartão de acesso (como crachás RFID ou cartões de proximidade) para outro dispositivo, permitindo acesso não autorizado. No cenário, o uso de RFID para copiar o sinal do crachá e replicá-lo em um cartão virgem é um exemplo clássico de clonagem de credenciais físicas. A CompTIA Security+ aborda ataques físicos e contramedidas, como o uso de cartões com criptografia ou autenticação mútua para prevenir clonagem.

✗ **Por que as outras estão erradas:**

- *Tailgating*: Tailgating é a prática de seguir fisicamente uma pessoa autorizada através de uma porta segura sem usar credenciais próprias. Não envolve clonagem de cartões ou RFID; é uma intrusão física passiva. A alternativa é incorreta porque o enunciado descreve a cópia eletrônica de credenciais, não a entrada por proximidade.
- *Shoulder surfing*: Shoulder surfing é a observação direta por cima do ombro para obter informações como senhas ou PINs. Não envolve RFID ou clonagem de crachás. A alternativa é incorreta porque é uma técnica de observação visual, não de duplicação eletrônica.
- *Dumpster diving*: Dumpster diving é a busca em lixeiras por informações descartadas

(documentos, mídias) que possam ser úteis ao atacante. Não tem relação com RFID ou clonagem de credenciais. A alternativa é incorreta porque se trata de recuperação de dados descartados, não de interceptação e cópia de sinais de cartão.

5) D — Implementar a solução correspondente: BEC: o email SE PASSA pelo executivo (vítima interna)....

✓ **Por que está certa:** Conforme os objetivos oficiais do exame CompTIA Security+ (SY0-701) para a aula 2.2 (Impersonation): BEC: o email SE PASSA pelo executivo (vítima interna).

✗ **Por que as outras estão erradas:**

- *Desativar temporariamente os logs de auditoria para acelerar o throughput do sistema:* Viola frontalmente o pilar de Accounting e a rastreabilidade forense. Sem logs, a equipe fica cega para detectar incidentes e quebra normas de conformidade (PCI DSS, ISO 27001).
- *Substituir controles técnicos preventivos por termos de adesão informais:* Termos informais são controles administrativos, dependem exclusivamente da conduta do usuário e não bloqueiam ataques automatizados, injeções ou malwares em tempo de execução.
- *Permitir acesso compartilhado entre administradores com credenciais genéricas:* Destrói a responsabilização individual (Accountability) e o Não-repúdio. Torna impossível comprovar quem realizou alterações críticas ou comandos maliciosos.

6) C — Implementar a solução correspondente: Whaling: o email MIRA o executivo (spear de exec) — diferente de BEC....

✓ **Por que está certa:** Conforme os objetivos oficiais do exame CompTIA Security+ (SY0-701) para a aula 2.2 (Impersonation): Whaling: o email MIRA o executivo (spear de exec) — diferente de BEC.

✗ **Por que as outras estão erradas:**

- *Desativar temporariamente os logs de auditoria para acelerar o throughput do sistema:* Viola frontalmente o pilar de Accounting e a rastreabilidade forense. Sem logs, a equipe fica cega para detectar incidentes e quebra normas de conformidade (PCI DSS, ISO 27001).
- *Substituir controles técnicos preventivos por termos de adesão informais:* Termos informais são controles administrativos, dependem exclusivamente da conduta do usuário e não bloqueiam ataques automatizados, injeções ou malwares em tempo de execução.
- *Permitir acesso compartilhado entre administradores com credenciais genéricas:* Destrói a responsabilização individual (Accountability) e o Não-repúdio. Torna impossível comprovar quem realizou alterações críticas ou comandos maliciosos.

7) A — Implementar a solução correspondente: Tailgating: entra na porta atrás de quem tem acesso....

✓ **Por que está certa:** Conforme os objetivos oficiais do exame CompTIA Security+ (SY0-701) para a aula 2.2 (Impersonation): Tailgating: entra na porta atrás de quem tem acesso.

✗ **Por que as outras estão erradas:**

- *Desativar temporariamente os logs de auditoria para acelerar o throughput do sistema:* Viola frontalmente o pilar de Accounting e a rastreabilidade forense. Sem logs, a equipe fica cega para detectar incidentes e quebra normas de conformidade (PCI DSS, ISO 27001).
- *Substituir controles técnicos preventivos por termos de adesão informais:* Termos informais são controles administrativos, dependem exclusivamente da conduta do usuário e não bloqueiam ataques automatizados, injeções ou malwares em tempo de execução.
- *Permitir acesso compartilhado entre administradores com credenciais genéricas:* Destrói a

responsabilização individual (Accountability) e o Não-repúdio. Torna impossível comprovar quem realizou alterações críticas ou comandos maliciosos.

8) C — Implementar a solução correspondente: 'sender claims to be an executive' = BEC....

✓ **Por que está certa:** Conforme os objetivos oficiais do exame CompTIA Security+ (SY0-701) para a aula 2.2 (Impersonation): 'sender claims to be an executive' = BEC.

✗ **Por que as outras estão erradas:**

- *Desativar temporariamente os logs de auditoria para acelerar o throughput do sistema:* Viola frontalmente o pilar de Accounting e a rastreabilidade forense. Sem logs, a equipe fica cega para detectar incidentes e quebra normas de conformidade (PCI DSS, ISO 27001).
- *Substituir controles técnicos preventivos por termos de adesão informais:* Termos informais são controles administrativos, dependem exclusivamente da conduta do usuário e não bloqueiam ataques automatizados, injeções ou malwares em tempo de execução.
- *Permitir acesso compartilhado entre administradores com credenciais genéricas:* Destrói a responsabilização individual (Accountability) e o Não-repúdio. Torna impossível comprovar quem realizou alterações críticas ou comandos maliciosos.

9) B — Implementar a solução correspondente: 'follows an authorized person through a door' = tailgating/piggybacking....

✓ **Por que está certa:** Conforme os objetivos oficiais do exame CompTIA Security+ (SY0-701) para a aula 2.2 (Impersonation): 'follows an authorized person through a door' = tailgating/piggybacking.

✗ **Por que as outras estão erradas:**

- *Desativar temporariamente os logs de auditoria para acelerar o throughput do sistema:* Viola frontalmente o pilar de Accounting e a rastreabilidade forense. Sem logs, a equipe fica cega para detectar incidentes e quebra normas de conformidade (PCI DSS, ISO 27001).
- *Substituir controles técnicos preventivos por termos de adesão informais:* Termos informais são controles administrativos, dependem exclusivamente da conduta do usuário e não bloqueiam ataques automatizados, injeções ou malwares em tempo de execução.
- *Permitir acesso compartilhado entre administradores com credenciais genéricas:* Destrói a responsabilização individual (Accountability) e o Não-repúdio. Torna impossível comprovar quem realizou alterações críticas ou comandos maliciosos.

10) B — Implementar a solução correspondente: Cenário: 'atacante manda email dizendo ser o CEO e pede transferência urgen....

✓ **Por que está certa:** Conforme os objetivos oficiais do exame CompTIA Security+ (SY0-701) para a aula 2.2 (Impersonation): Cenário: 'atacante manda email dizendo ser o CEO e pede transferência urgente' = BEC — não whaling (whaling MIRA o CEO; BEC SE PASSA por ele)..

✗ **Por que as outras estão erradas:**

- *Desativar temporariamente os logs de auditoria para acelerar o throughput do sistema:* Viola frontalmente o pilar de Accounting e a rastreabilidade forense. Sem logs, a equipe fica cega para detectar incidentes e quebra normas de conformidade (PCI DSS, ISO 27001).
- *Substituir controles técnicos preventivos por termos de adesão informais:* Termos informais são controles administrativos, dependem exclusivamente da conduta do usuário e não bloqueiam ataques automatizados, injeções ou malwares em tempo de execução.
- *Permitir acesso compartilhado entre administradores com credenciais genéricas:* Destrói a

responsabilização individual (Accountability) e o Não-repúdio. Torna impossível comprovar quem realizou alterações críticas ou comandos maliciosos.